

Vulnerability Assessment Report for a Live Website

Project Title: Vulnerability Assessment Report for a Live Website

Target Website: <http://demo.owasp-juice.shop/>

Internship Domain: Cyber Security

Submitted by: Surayya Banu K

Program: Cyber Security Internship

Organization: Future Interns

Date: 16/08/2026

1.Objective

This report presents the results of a security assessment conducted on the OWASP Juice Shop web application. The objective was to identify vulnerabilities and security weaknesses that could impact application security, user data, and overall system integrity.

The assessment identified multiple security alerts and potential weaknesses during the web application and network security analysis. The findings were reviewed and documented according to their potential impact, with appropriate recommendations provided to improve the overall security posture of the application.

2.Scope

☆ Target: demo.owasp-juice.shop (OWASP Juice Shop demo application)

☆ Testing Type: Black-box testing (no source code access)

☆ Approach: Automated and manual vulnerability scanning

☆ Focus Areas:

- o Web application vulnerabilities
- o Security misconfigurations and HTTP security headers
- o Network exposure and open services
- o Information disclosure

3. Tools Used

3.a OWASP ZAP:

Used to scan the web application and identify security alerts, headers and other risks.

3.b Nmap/Zenmap

Used to identify open ports ,running services and network exposures.

3.c Chrome DevTools

Used to inspect network requests, HTTP headers, and browser security information.

3.d Canva

Used to design the final vulnerability assessment report.

4. Skills Gained

- Vulnerability analysis and identification
- Risk classification
- Network scanning and service identification
- Web application security understanding
- Security reporting and documentation
- Problem solving in practical security scenarios

5. Key Features of the Assessment

- Identification of web application vulnerabilities
- Classification of vulnerabilities based on risk levels
- Analysis of security misconfigurations
- Examination of HTTP security headers and cookies
- Documentation of findings with supporting evidence
- Recommended remediation measures

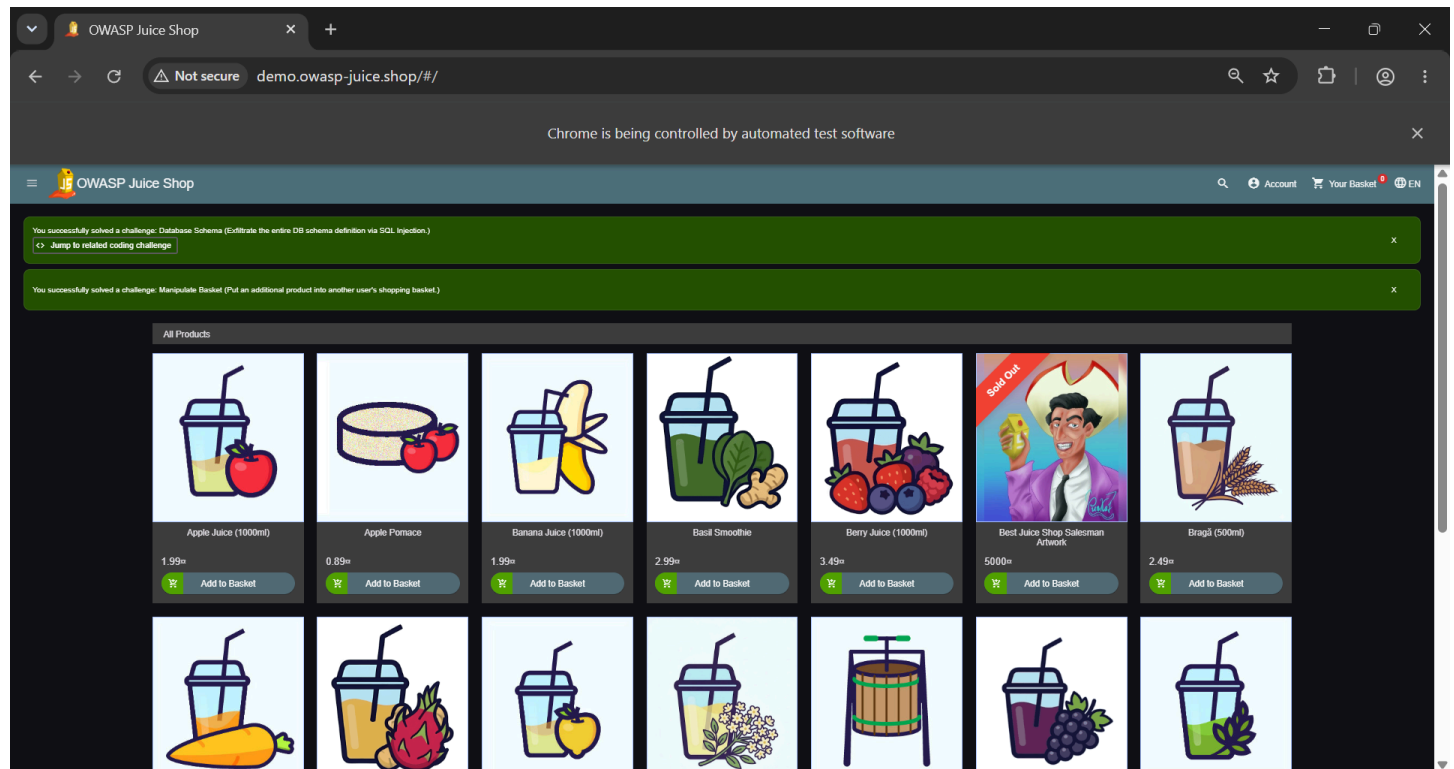
6. Deliverable

The deliverable is a Vulnerability Assessment Report for the OWASP Juice Shop application. The report documents the identified security findings, supporting evidence, risk levels, and recommended remediation steps. The completed report is uploaded to the GitHub repository for evaluation.

7.Methodology

7.a Web Application Assessment (OWASP ZAP)

1. Launched OWASP ZAP.
2. Selected Manual Scan.
3. Entered the target URL: "http://demo.owasp-juice.shop"



4. Opened and manually explored the web application.
5. Reviewed the security alerts under the Alerts tab.
6. Recorded relevant vulnerabilities and captured screenshots as evidence.

7.b Network Scanning (Nmap)

1. Opened Command Prompt.
2. Entered the command: "nmap -T4 -F demo.owasp-juice.shop"
3. Executed the Nmap scan.
4. Reviewed the detected open ports, state and services.
5. Recorded the relevant network exposure findings.

7.c Browser DevTools Analysis

1. Opened Chrome DevTools.
2. Inspected Network requests and responses.
3. Examined HTTP response headers.

4. Checked cookies and security-related settings.
5. Opened the Security panel to review the page security status.
6. Recorded relevant security observations as evidence.

8.Detailed Findings



▼  Alerts (14)

>  SQL Injection

>  CSP: Failure to Define Directive with No Fallback

>  Content Security Policy (CSP) Header Not Set (Systemic)

>  Cross-Domain Misconfiguration (Systemic)

>  Missing Anti-clickjacking Header (3)

>  Session ID in URL Rewrite (Systemic)

>  Application Error Disclosure (5)

>  Private IP Disclosure

>  Server Leaks Version Information via "Server" HTTP Header

>  Strict-Transport-Security Header Not Set (Systemic)

>  Timestamp Disclosure - Unix (Systemic)

Alerts  1  5  6  2 Main Proxy: localhost:8080

8.a SQL Injection

Untitled Session - Session1 - ZAP 2.17.0

Standard Mode

Quick Start Request Response Requester

Header: Text Body: Text

HTTP/1.1 500 Internal Server Error
Date: Sat, 15 Aug 2026 09:18:07 GMT
Server: Heroku
Access-Control-Allow-Origin: *
Content-Type: text/html; charset=utf-8
Feature-Policy: payment 'self'
Nel: {"report_to": "heroku-nel", "response_headers": [{"Via"}], "max_age": 3600, "success_fraction": 0.01, "failure_fraction": 0.1}
Report-To: {"group": "heroku-nel", "endpoints": [{"url": "https://heroku-nel.heroku.com"}]}

<html>
<head>
<meta charset='utf-8'>
<title>Error: SQLITE_ERROR: near "("; syntax error</title>
<style>{
margin: 0;
padding: 0;
outline: 0;
}

History Search Alerts Output Spider Client Spider Active Scan

Alerts (14)

SQL Injection

URL: http://demo.owasp-juice.shop/rest/products/search?q=%27%28
Risk: High
Confidence: Low
Parameter: q
Attack: '
Evidence: HTTP/1.1 500 Internal Server Error
CWE ID: 89
WASC ID: 19
Source: Active (40018 - SQL Injection)
Input Vector: URL Query String
Description:
SQL injection may be possible.

Alerts 1 5 6 2 Main Proxy: localhost:8080 Current Status 0 2 0 0 0 0 0 0 0 0 0 0

Spider Client Spider Active Scan

SQL Injection

URL: http://demo.owasp-juice.shop/rest/products/search?q=%27%28

Risk: High

Confidence: Low

Parameter: q

Attack: '

Evidence: HTTP/1.1 500 Internal Server Error

CWE ID: 89

WASC ID: 19

Source: Active (40018 - SQL Injection)

Input Vector: URL Query String

Description:
SQL injection may be possible.

Risk Level: High

Description:

The application may allow SQL queries to be manipulated through user input.

Impact:

Unauthorized database access

Data theft or modification

Recommendation:

Use parameterized queries and validate all input on the server side, and do not rely on client side validation alone.

8.b CSP Header Not Set

Content Security Policy (CSP) Header Not Set	
URL:	https://demo.owasp-juice.shop/
Risk:	 Medium
Confidence:	High
Parameter:	
Attack:	
Evidence:	
CWE ID:	693
WASC ID:	15
Source:	Passive (10038 - Content Security Policy (CSP) Header Not Set)
Alert Reference:	10038-1
Input Vector:	
Description:	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cr

Risk Level: Medium

Description:

The application does not include a Content Security Policy header.

Impact:

Increased risk of XSS and other client-side attacks.

Recommendation:

Implement a properly configured Content Security Policy header.

8.c Cross-Domain Misconfiguration

Cross-Domain Misconfiguration	
URL:	https://demo.owasp-juice.shop/
Risk:	 Medium
Confidence:	Medium
Parameter:	
Attack:	
Evidence:	Access-Control-Allow-Origin: *
CWE ID:	264
WASC ID:	14
Source:	Passive (10098 - Cross-Domain Misconfiguration)
Input Vector:	
Description:	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

Risk Level: Medium

Description:

The application does not include a Content Security Policy header.

Impact:

Increased risk of XSS and other client-side attacks.

Recommendation:

Implement a properly configured Content Security Policy header.

8.d Session ID in URL Rewrite

Session ID in URL Rewrite	
URL:	http://demo.owasp-juice.shop/socket.io/?EIO=4&transport=websocket&sid=x0cif9DFLJj6M8VwAAMT
Risk:	 Medium
Confidence:	High
Parameter:	sid
Attack:	
Evidence:	x0cif9DFLJj6M8VwAAMT
CWE ID:	598
WASC ID:	13
Source:	Passive (3 - Session ID in URL Rewrite)
Alert Reference:	3-1
Input Vector:	
Description:	URL rewrite is used to track user session ID. The session ID may be disclosed via cross-site referer header. In addition, the session ID might be stored in browser history

Risk Level: Medium

Description:

A session ID is included in the URL, which may expose the session identifier.

Impact:

Session ID may be disclosed through browser history or referrer information.

Recommendation:

Store session identifiers in secure cookies instead of URLs.

8.e Application Error Disclosure

Application Error Disclosure	
URL:	http://demo.owasp-juice.shop/rest
Risk:	 Low
Confidence:	Medium
Parameter:	
Attack:	
Evidence:	HTTP/1.1 500 Internal Server Error
CWE ID:	550
WASC ID:	13
Source:	Passive (90022 - Application Error Disclosure)
Input Vector:	
Description:	This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.

Risk Level: Low

Description:

The application displays error information that may reveal internal implementation details.

Impact:

Information disclosure that may assist further attacks.

Recommendation:

Display generic error messages to users and keep detailed errors in secure server-side logs

8.f Private IP Disclosure

Private IP Disclosure	
URL:	http://demo.owasp-juice.shop/rest/admin/application-configuration
Risk:	🟡 Low
Confidence:	Medium
Parameter:	
Attack:	
Evidence:	192.168.99.100:3000
CWE ID:	497
WASC ID:	13
Source:	Passive (2 - Private IP Disclosure)
Input Vector:	
Description:	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.

Risk Level: Low

Description:

A private IP address (192.168.99.100:3000) is exposed in the HTTP response.

Impact:

Reveals internal network information that may assist reconnaissance.

Recommendation:

Remove internal IP addresses and other internal network details from public responses.

8.g X-Content-Type-Options Header Missing

X-Content-Type-Options Header Missing	
URL:	https://clientservices.googleapis.com/uma/v2
Risk:	 Low
Confidence:	Medium
Parameter:	x-content-type-options
Attack:	
Evidence:	
CWE ID:	693
WASC ID:	15
Source:	Passive (10021 - X-Content-Type-Options Header Missing)
Input Vector:	
Description:	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and

Risk Level: Low

Description:

The application does not set the X-Content-Type-Options header to prevent MIME-type sniffing.

Impact:

May increase the risk of content-type confusion attacks.

Recommendation:

Set the X-Content-Type-Options header to nosniff.

8.h Modern Web Application

Modern Web Application	
URL:	https://demo.owasp-juice.shop/
Risk:	 Informational
Confidence:	Medium
Parameter:	
Attack:	
Evidence:	<pre> <script> window.addEventListener("load", function(){ window.cookieconsent.initialise({ "palette": { "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" }, "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" } }, "theme": "classic", "position": "bottom right" }); }); </pre>

Risk Level: Informational

Description:

The application is identified as a modern web application using client-side technologies.

Impact:

No direct security impact; this is an informational finding.

Recommendation:

No immediate action is required. Continue to follow secure development practices and regularly assess client-side components.

9. Network Scan Results(Nmap)

```
nmap -T4 -F demo.owasp-juice.shop

Starting Nmap 7.991 ( https://nmap.org ) at 2026-08-16 15:12 +0530
Warning: Hostname demo.owasp-juice.shop resolves to 2 IPs. Using 81.169.145.156.
Nmap scan report for demo.owasp-juice.shop (81.169.145.156)
Host is up (0.31s latency).
Other addresses for demo.owasp-juice.shop (not scanned): 2a01:238:20a:202:1156::
rDNS record for 81.169.145.156: w9c.rzone.de
Not shown: 96 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
443/tcp   open  https
8080/tcp   open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 3.98 seconds
```

Command Used: nmap -T4 -F demo.owasp-juice.shop

Findings:

- Port 21 (FTP):OPEN
- Port 80 (HTTP):OPEN
- Port 443 (HTTPS):OPEN
- Port 8080 (HTTP):OPEN

Impact:

- Increases the attack surface of the target.
- Exposed services may be targeted if they are misconfigured or outdated.
- FTP may expose sensitive information if not securely configured.
- Attackers can use open services for further reconnaissance.

Recommendation:

- Close unnecessary or unused ports.
- Restrict access to required services using firewall rules.
- Keep exposed services updated and securely configured.
- Use secure protocols such as HTTPS instead of unencrypted alternatives where applicable.

10. Conclusion

The OWASP Juice Shop application contains multiple security vulnerabilities identified through OWASP ZAP and Nmap. The findings include SQL Injection, CSP-related issues, security misconfigurations, session-related weaknesses, and information disclosure.

The Nmap scan revealed multiple open ports and exposed services that require proper configuration and monitoring.

Addressing the high- and medium-risk vulnerabilities first, followed by improving security headers, session management, input validation, and exposed services, will significantly improve the overall security posture of the application. The target application (OWASP Juice Shop) is a deliberately vulnerable application designed for security testing and learning.

11. Key Highlights:

- ☆ Professional vulnerability assessment and reporting
- ☆ Clear risk prioritization
- ☆ Nmap-based network/service assessment
- ☆ OWASP ZAP-based web vulnerability identification
- ☆ Business-friendly explanations and remediation recommendations